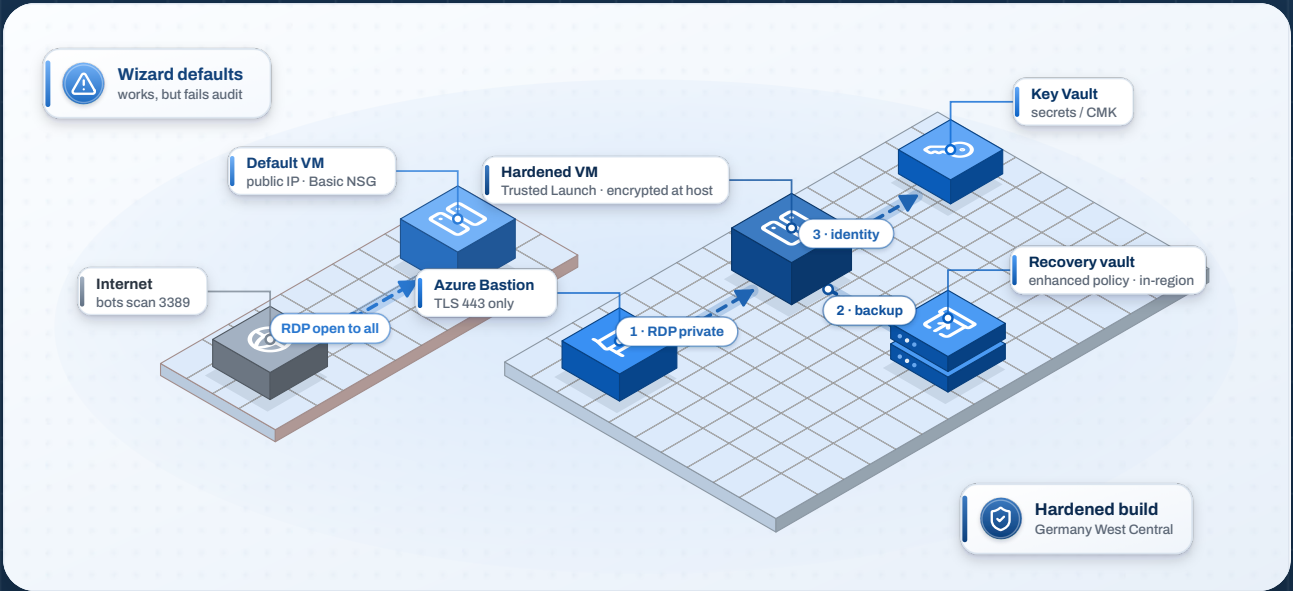
STANDARD OPERATING PROCEDURE · FIELD GUIDE SERIES

SOP-AZ-002

Deploying a Hardened Azure VM in a Data-Residency Region

A Trusted Launch Windows Server VM with encryption at host, no public IP, backup and monitoring, built four ways (portal, Az PowerShell, Azure CLI, Bicep) and kept in-region by Azure Policy.

Microsoft Azure | Compute & Security | Compliance



DOCUMENT ID	SOP-AZ-002
VERSION	2.0
EFFECTIVE	October 2026
AUDIENCE	Cloud administrators, systems engineers, security and compliance reviewers
AUTHOR	Richmond Dieujuste, Principal Consultant

Rich Dieu IT Solutions LLC · richdieu.com

Sanitized reference edition — client identifiers removed

Contents

1. Concepts You Need First 3

1.1 Regions, zones and data residency 3

1.2 What a VM is made of 4

1.3 The security features you will switch on 5

1.4 Three layers of disk encryption 6

1.5 Choosing a method 7

2. Access, Prerequisites and Planning 8

2.1 Level of access required 8

2.2 Prerequisites checklist 9

2.3 Naming and planning decisions 10

3. Method A · Azure Portal, Tab by Tab 11

4. Method B · Az PowerShell Base Template 16

5. Methods C and D · Azure CLI, Bicep and Policy Guardrails 19

5.1 Method C · Azure CLI 19

5.2 Method D · Bicep template 19

5.3 Guardrails with Azure Policy 21

6. Verification, Cost, Rollback and Troubleshooting 23

6.1 Verification checklist 23

6.2 Cost considerations 23

6.3 Rollback 24

6.4 Troubleshooting 25

7. Summary, Glossary and Review 26

7.1 Summary 26

7.2 Glossary 26

LEARNING OBJECTIVES

After working through this procedure you will be able to:

- Explain what a data-residency region, an availability zone and a paired region are, and what region choice does and does not guarantee.

- Configure every tab of the VM creation wizard and justify each security setting: Trusted Launch, encryption at host, NSG, no public IP, managed identity, hotpatch and boot diagnostics.
- Distinguish server-side encryption with platform or customer-managed keys from encryption at host and Azure Disk Encryption.
- Deploy the same hardened VM with an Az PowerShell template, the Azure CLI and a Bicep file, producing an evidence record.
- Enforce region, tag and encryption guardrails with Azure Policy and grant the least-privilege RBAC roles for each task.
- Verify, cost, troubleshoot and roll back the deployment.

TIME	DIFFICULTY	MINIMUM ROLE	RISK
≈ 45 min portal · 10 min scripted	Intermediate	Virtual Machine Contributor (RG) + subnet join	Low (new resource), high if exposed publicly

CHAPTER 1

Concepts You Need First

Creating a virtual machine in Azure takes about five minutes. Creating one that an auditor will accept takes the same five minutes plus about forty decisions, most of which hide behind default values on seven wizard tabs. This SOP walks through every one of those decisions for a production Windows Server web VM that must keep its data inside a specific geography. The worked example uses **Germany West Central**, a public Azure region often chosen for EU and German data-residency requirements, but the same procedure applies to any region your policy allows.

> **KEY CONCEPT · SECURE BY DEFAULT IS NOT THE SAME AS SECURE BY DESIGN**
>
> Azure's defaults are built to make the first VM work, not to pass an audit. The default Networking tab, for example, opens RDP (port 3389) to the whole internet. Hardening is the practice of replacing each convenient default with a deliberate, documented choice, and then enforcing those choices with policy so the next person cannot quietly revert them.

1.1 Regions, zones and data residency

Term	Meaning	In the worked example
Region	A set of datacenters in one metropolitan area, connected by a low-latency network. Every resource is created in exactly one region.	Germany West Central (Frankfurt area), API name `germanywestcentral`.
Availability zone	A physically separate datacenter group inside a region, with independent power, cooling and network. Spreading VMs across zones protects against a datacenter failure.	Three zones. One VM per zone gives the 99.99% multi-zone VM SLA.
Geography	The market boundary (for example Germany, or the EU) that defines data-residency commitments.	Germany; also inside the EU Data Boundary.
Paired region	A second region in the same geography used for platform-sequenced updates and geo-redundant storage replication.	Germany North (access-restricted; requested through support).

Data residency means data at rest stays in a chosen geography. Choosing the region is necessary but not sufficient: backups, logs, diagnostic storage and disaster-recovery

replicas must also stay in-region, and an *Allowed locations* policy (Chapter 5) must stop anyone deploying elsewhere.

WATCH OUT · RESIDENCY IS NOT SOVEREIGNTY

A German region keeps data *stored* in Germany; it does not by itself change which laws can compel the cloud provider. Where the requirement is sovereignty (control over access, including by the provider), add customer-managed keys in Azure Key Vault Managed HSM, confidential computing, Microsoft's sovereign-cloud offerings, and a legal review. State the requirement precisely before choosing controls.

1.2 What a VM is made of

An Azure VM is a bundle of resources: the **compute** definition (size, zone, security type), a managed **OS disk** and optional data disks, a **network interface** (NIC) in a subnet, optionally a public IP, an optional **managed identity**, and **extensions** (agents installed by Azure). The wizard tabs map almost one-to-one onto these parts.

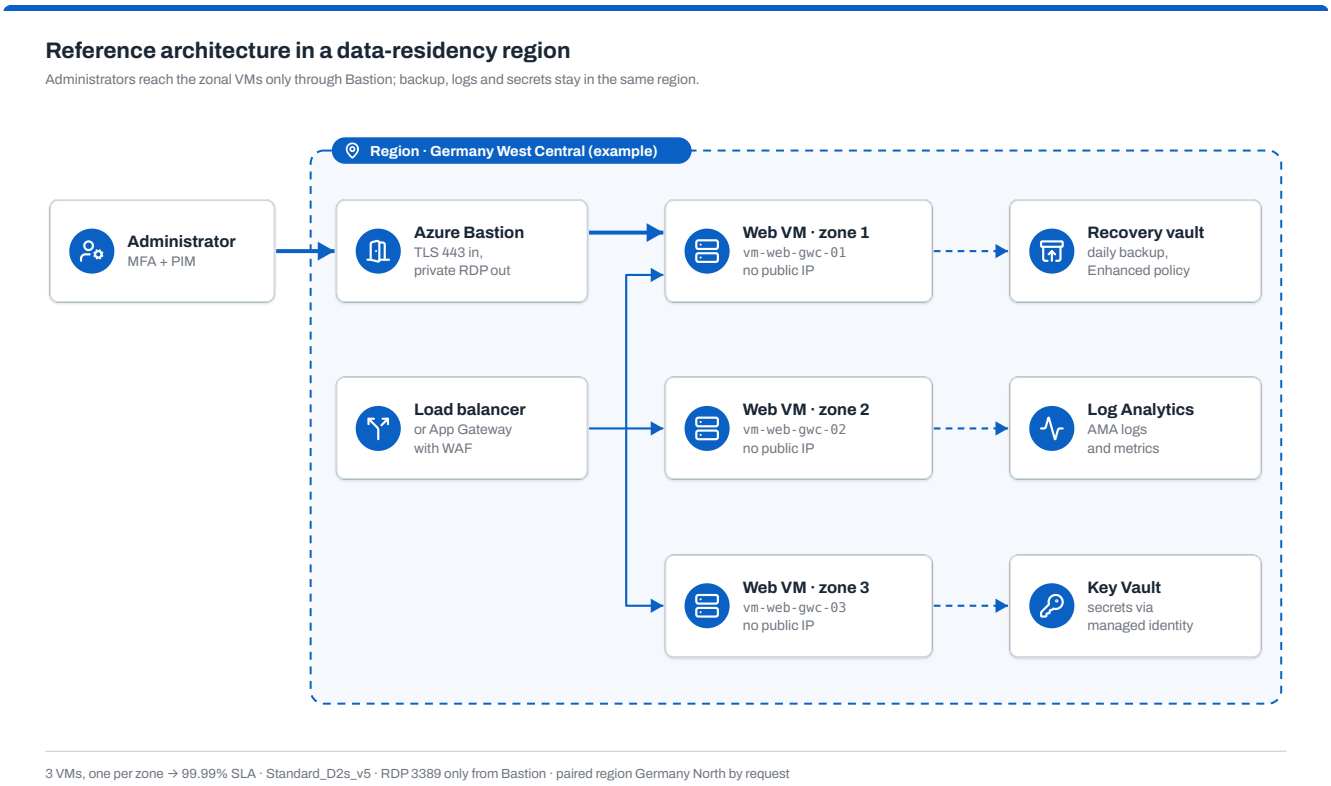


Figure 1. Nothing in this design has a public IP: the only way in for an administrator is Bastion, and every supporting service lives in the same region as the data.

1.3 The security features you will switch on



Figure 2. Each layer stops a different failure, so removing any one of them leaves a gap the others cannot cover.

Feature	What it does and why it matters
Trusted Launch	A VM security type that adds **Secure Boot** (only signed boot loaders and drivers run), a virtual **TPM** (measured boot, BitLocker keys, attestation) and **boot integrity monitoring** in Defender for Cloud. Defends against bootkits and rootkits. Requires a Generation 2 image.
Encryption at host	Encrypts the temporary disk and the OS/data disk caches on the physical host, so data is encrypted before it leaves the server. Closes the gap that server-side encryption alone leaves.
NSG + no public IP	A network security group is a stateful allow/deny rule list on a subnet or NIC. With no public IP the VM is unreachable from the internet; administrators come in through Bastion.
Azure Bastion	A managed jump host that brokers RDP/SSH over TLS from the portal (or native client on Standard SKU) to the VM's private IP.
Managed identity	An Entra ID identity for the VM itself. Code on the VM gets tokens for Key Vault, Storage or SQL without any stored password.
Hotpatch	On Windows Server Azure Edition, most monthly security updates install in memory without a reboot; baseline reboots occur roughly quarterly.

Boot diagnostics	Captures a console screenshot and serial log so you can see why a VM will not boot when you cannot connect to it.
Tags + Azure Policy	Tags are name/value metadata (Owner, Environment, DataClassification). Policy can require them and deny non-compliant deployments.

1.4 Three layers of disk encryption

Every managed disk is encrypted at rest with AES-256 **server-side encryption (SSE)**; this cannot be turned off. What you choose is *who holds the key* (Microsoft by default, or you with a customer-managed key in Key Vault through a *disk encryption set*) and whether to add **encryption at host** for the caches and temp disk. Azure Disk Encryption (BitLocker inside the guest) is the older approach; Microsoft has announced its retirement and recommends encryption at host instead.

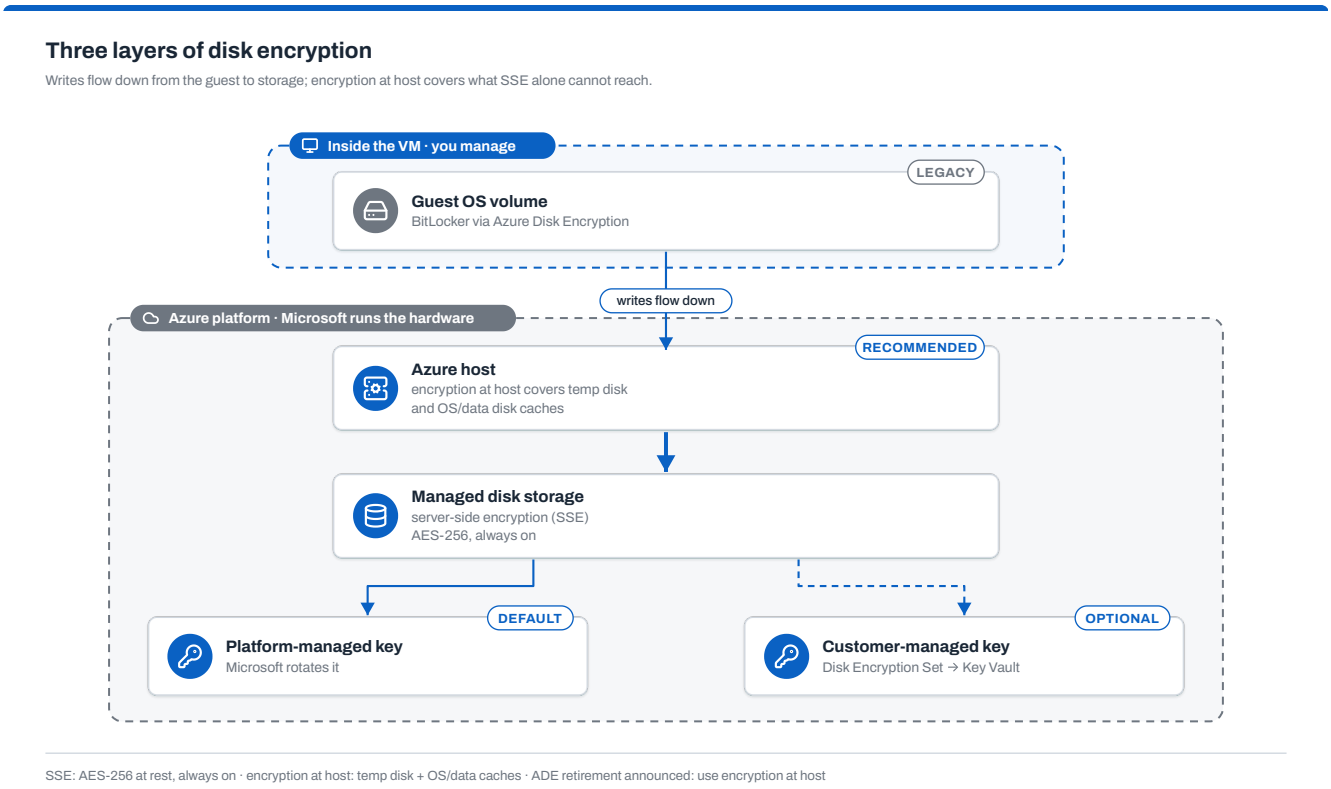


Figure 3. SSE is already on for every disk; adding encryption at host closes the temp-disk and cache gap without any agent in the guest.

1.5 Choosing a method

A · Azure portal

The seven-tab wizard, tab by tab, with the reasoning for every field.

BEST FOR: FIRST BUILD, LEARNING

B · Az PowerShell

Parameterized template with Trusted Launch, encryption at host, AMA, backup and an evidence file.

BEST FOR: AUDITED, REPEATABLE BUILDS

C · Azure CLI

One `az vm create` plus follow-up commands; ideal in Cloud Shell or Bash pipelines.

BEST FOR: LINUX/DEVOPS ADMINS

D · Bicep

Declarative template, reviewed in pull requests, previewed with what-if.

BEST FOR: INFRASTRUCTURE AS CODE

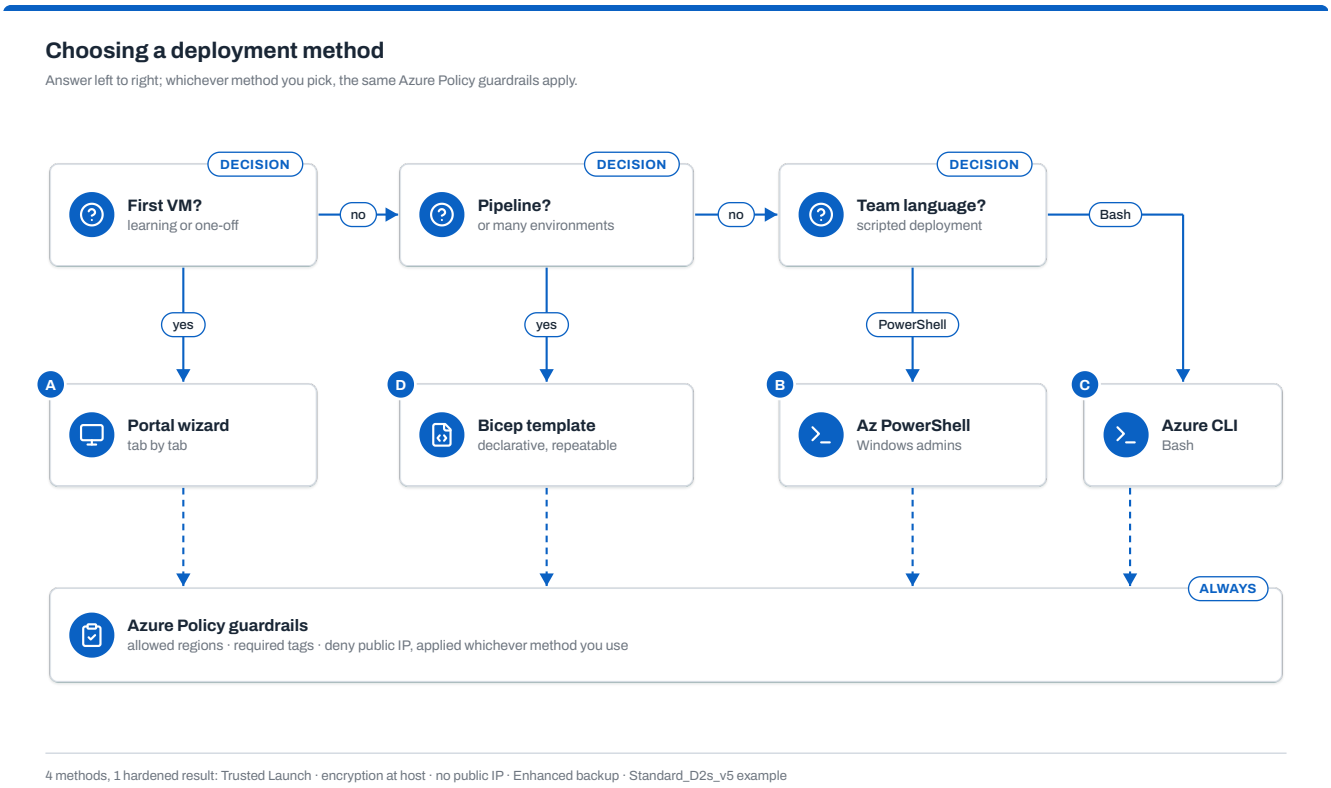


Figure 4. Pick the method that fits your team, not the result: all four produce the same hardened VM and all four are checked by the same policies.

CHAPTER 2

Access, Prerequisites and Planning

2.1 Level of access required

Grant roles at the narrowest scope that works. The VM lives in a workload resource group; the virtual network usually lives in a separate networking resource group owned by another team, so subnet access is granted separately.

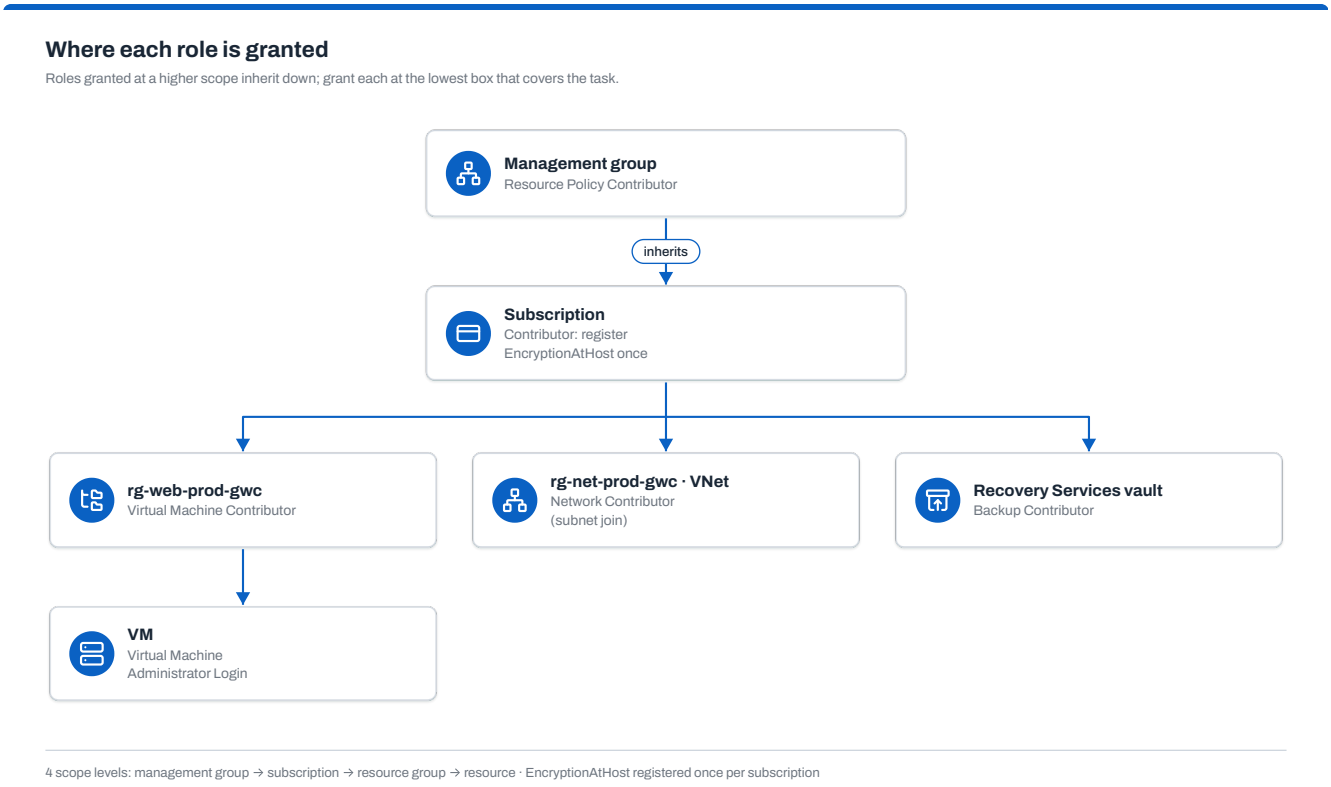


Figure 5. Grant each role at the lowest scope that covers the task, because anything granted higher up is inherited by everything beneath it.

Task	Least-privilege built-in role (scope)	Notes
Create VM, disks, NIC	Virtual Machine Contributor (workload RG)	Does not grant access *into* the VM or to the VNet.
Place the NIC in a subnet	Network Contributor (VNet or subnet), or a custom role with `subnets/join/action`	Usually requested from the network team.

Register encryption at host	Contributor (subscription), one-time	`Microsoft.Features/providers/features/register/action`.
Enable backup	Backup Contributor (vault) + VM Contributor (VM)	Backup Operator suffices for on-demand backups.
Customer-managed key	Key Vault Crypto Officer (vault) + Contributor (disk encryption set)	Only if CMK is required.
Monitoring (AMA + DCR)	Monitoring Contributor (RG) + Log Analytics Contributor (workspace)	Associates the VM with a data collection rule.
Sign in with Entra ID	Virtual Machine Administrator Login or User Login (VM/RG)	Needed even for Owners.
Connect through Bastion	Reader on the VM, its NIC and the Bastion resource	Plus a guest-OS login.
Assign guardrail policies	Resource Policy Contributor (management group or subscription)	Platform team, not the VM builder.

> **GOOD PRACTICE · JUST-IN-TIME PRIVILEGE**
>
> Make Virtual Machine Contributor and Network Contributor *eligible* PIM assignments with MFA, a ticket number and a short duration. The activation record becomes part of your change evidence.

2.2 Prerequisites checklist

- [ ] Approved change (e.g. `CHG0012345`), the approved region list and the tag standard.
- [ ] Resource group `rg-web-prod-gwc` in the target region; VNet `vnet-prod-gwc` with subnet `snet-web` (for example `10.20.1.0/24`) and an NSG; `AzureBastionSubnet` with Bastion deployed.
- [ ] vCPU quota for the chosen VM family in the region (**Subscriptions › Usage + quotas**).
- [ ] `EncryptionAtHost` feature registered on the subscription (Chapter 3, Disks).

- [ ] Recovery Services vault and Log Analytics workspace in the *same* region; a data collection rule for Windows events and counters.
- [ ] Local admin password generated and stored in Key Vault (never in tickets or documents).

2.3 Naming and planning decisions

Use a readable, generic convention such as the Cloud Adoption Framework pattern `<type>-<workload>-<region>-<nn>`: `vm-web-gwc-01`, `rg-web-prod-gwc`, `nsg-snet-web`. Avoid encoding secrets or internal topology in names, and remember that the Windows computer name is limited to 15 characters.

Decision	Guidance for a production web VM
Size	A current general-purpose family with premium storage (e.g. `Standard_D2s_v5`); the reference screenshots show `D2s_v3`. Confirm Trusted Launch and zone support for the size.
Zones	One VM per zone (1, 2, 3) behind a load balancer for 99.99%.
Image	Windows Server 2025 Datacenter: Azure Edition, Gen2 (hotpatch capable).
Keys	Platform-managed unless a regulation or contract requires customer-managed keys.
Access	Bastion only. No public IP. Entra ID login for named administrators.

CHAPTER 3

Method A · Azure Portal, Tab by Tab

Open **Virtual machines** from the services bar (or **All services › Compute › Virtual machines**), then **+ Create** › **Azure virtual machine**. Do not use **Review + create** early: it accepts every default on the tabs you skipped.

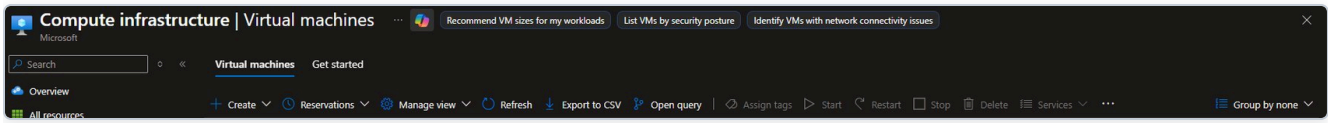


Figure 6. The Virtual machines blade. **Create** opens the wizard; **Group by** helps confirm the name is not already used in the subscription.

TAB 1 Basics: placement, image, size, administrator

1. **Subscription / Resource group**: the production subscription and `rg-web-prod-gwc`.
2. **Virtual machine name**: `vm-web-gwc-01`. Permanent; renaming means redeploying.
3. **Region**: *(Europe) Germany West Central*, or your approved region. If policy is in place, any other choice fails validation.
4. **Availability options**: *Availability zone*, self-selected, *Zone 1* (Zone 2 and 3 for the next VMs). The wizard can now create one VM per selected zone in one pass.
5. **Security type**: *Trusted launch virtual machines*; under **Configure security features** keep Secure Boot, vTPM and integrity monitoring on.
6. **Image**: *Windows Server 2025 Datacenter: Azure Edition - x64 Gen2*. Architecture x64 (Arm64 is not offered for this image).
7. **Size**: as planned. Leave **Azure Spot discount** off for production (Spot VMs can be evicted).
8. **Administrator account**: a non-obvious username (not `admin` or `administrator`, which Azure rejects anyway) and a 20+ character password taken from Key Vault. **Public inbound ports**: *None*. **Licensing**: tick Azure Hybrid Benefit only if you own eligible licences.

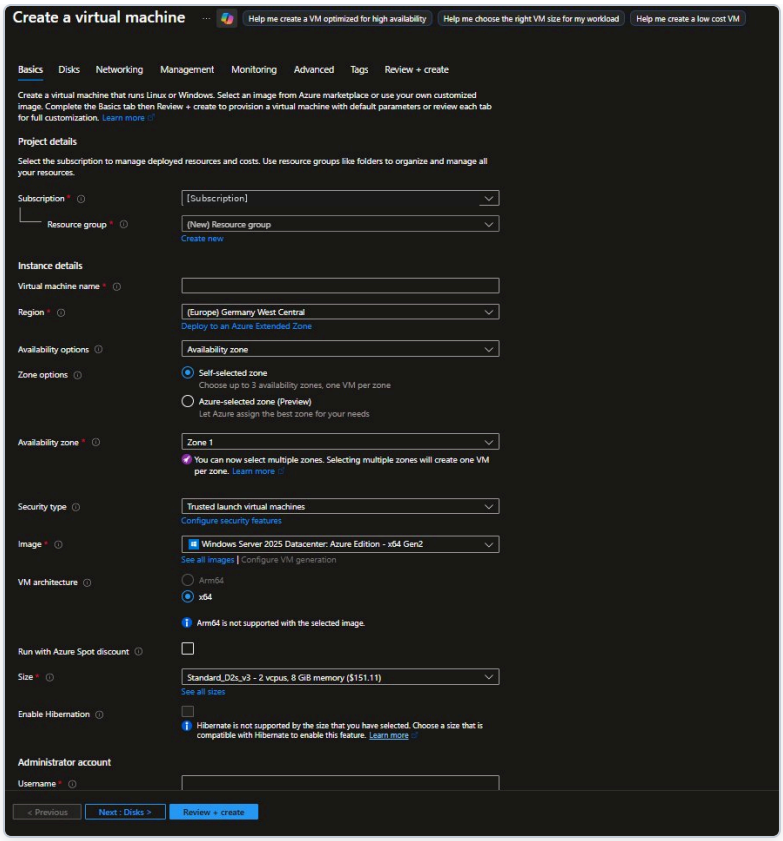


Figure 7. Basics tab with the example region, Zone 1, Trusted Launch and the Azure Edition Gen2 image. The subscription name has been replaced with a placeholder.

TABS 2–3 Disks and Networking

1. **Encryption at host**: tick it. If the portal says "*Encryption at host is not registered for the selected subscription*" (as in the screenshot), register the feature once with `Register-AzProviderFeature -FeatureName EncryptionAtHost -ProviderNamespace Microsoft.Compute`, wait until `Get-AzProviderFeature` reports *Registered*, then run `Register-AzResourceProvider -ProviderNamespace Microsoft.Compute`.
2. **OS disk**: image default 127 GiB, *Premium SSD (LRS)*, **Delete with VM** ticked, **Key management** *Platform-managed key* (or your disk encryption set for CMK). Leave Ultra Disk compatibility off.
3. **Data disks**: keep application content off `C:`. **Create and attach a new disk** (e.g. 256 GiB Premium SSD), host caching *Read-only* for static content. Record the LUN-to-drive mapping.
4. **Networking**: virtual network `vnet-prod-gwc`, subnet `snet-web`, **Public IP** *None*.

5. **NIC network security group**: *None* when the subnet already has an NSG (preferred: one rule set per subnet), or *Advanced* to pick an existing NSG. Never leave *Basic* with *Allow selected ports: RDP*; the portal itself warns that this allows all IP addresses.

6. Tick **Delete NIC when VM is deleted** and **Enable accelerated networking** (SR-IOV, no extra cost on supported sizes). **Load balancing**: add the VM to the existing load balancer or Application Gateway backend pool, or *None* for a single VM.

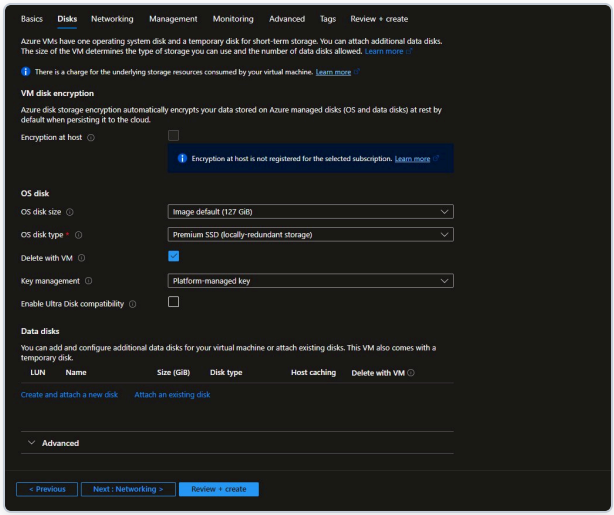


Figure 8. Disks tab: encryption at host (not yet registered here), Premium SSD, Delete with VM, platform-managed key.

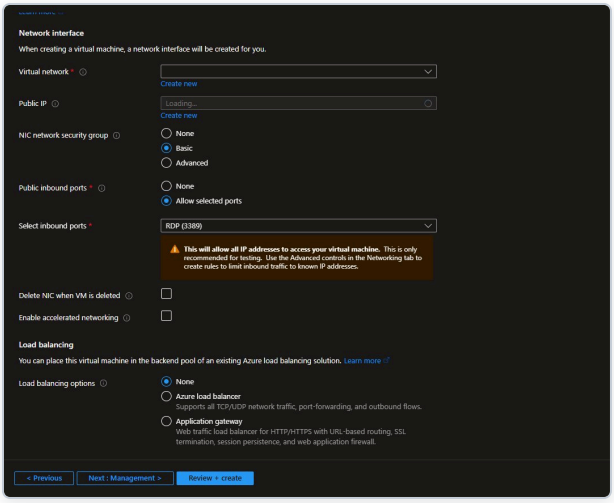


Figure 9. Networking tab defaults to avoid: Basic NSG with RDP open to all addresses, and NIC/accelerated-networking boxes unticked.

TABS 4–5 Management and Monitoring

1. **Microsoft Defender for Cloud**: confirm the banner shows the subscription is protected by Defender for Servers Plan 2 (adds Defender for Endpoint, vulnerability assessment, JIT, file integrity monitoring).

2. **Identity**: tick **Enable system assigned managed identity**. Then grant it only what it needs (for example *Key Vault Secrets User* on one vault).

3. **Login with Microsoft Entra ID**: tick it, and assign *Virtual Machine Administrator Login* to the admin group.

4. **Auto-shutdown**: off for production; on for dev/test.

5. **Backup**: tick **Enable backup**, choose the in-region vault and an **Enhanced** policy (required for Trusted Launch VMs), e.g. daily at 23:00 local, 30 daily and 12 monthly points.

6. **Site Recovery**: enable only if your DR design replicates to a second region that your residency rules also allow.
7. **Guest OS updates**: tick `Enable periodic assessment`, keep `Enable hotpatch`, patch orchestration *Azure-orchestrated* (safe deployment: zones and regions patched in sequence), reboot setting *Reboot if required*.
8. **Monitoring**: `Enable recommended alert rules` (CPU, memory, disk, network to an action group); boot diagnostics *Enable with managed storage account*; leave the legacy *OS guest diagnostics* off and use the Azure Monitor Agent with a data collection rule instead. Tick *application health monitoring* only for load-balanced or scale-set VMs.

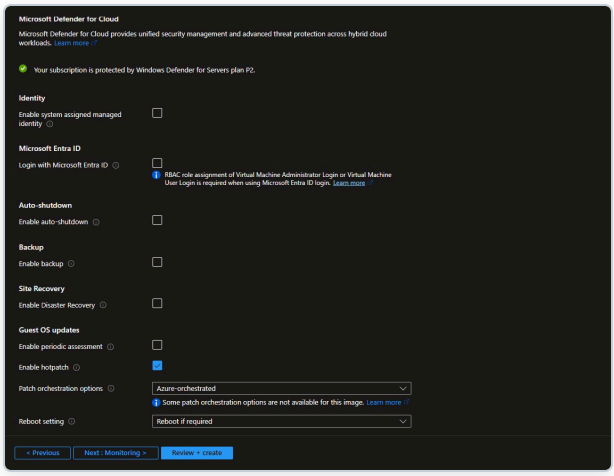


Figure 10. Management tab: Defender for Servers P2 active; identity, Entra login, backup and periodic assessment still need ticking; hotpatch is pre-enabled.

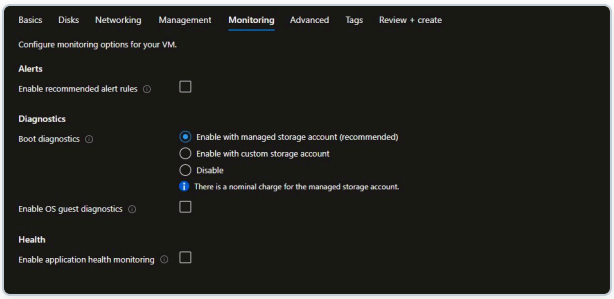


Figure 11. Monitoring tab: boot diagnostics with managed storage is the recommended default; tick the recommended alert rules.

TABS 6–7 Advanced, Tags, Review + create

1. **Extensions**: add *Azure Monitor Agent* and *Network Watcher Agent* (or let Azure Policy deploy them). Defender for Endpoint is installed automatically by Defender for Servers; the old Microsoft Antimalware extension is not needed alongside it.
2. **Custom data / User data**: leave empty unless you have a reviewed bootstrap script. Both are readable from inside the VM through the instance metadata service, so **never put secrets in them**; fetch secrets with the managed identity instead.

3. **Host group / Capacity reservations**: *None*, unless regulation requires dedicated hardware (Azure Dedicated Host) or you need guaranteed capacity.

4. **Tags**: `Environment=Production`, `Owner=web-platform-team`, `CostCenter=CC-1234`, `DataClassification=Confidential`, `DataResidency=DE`, `ComplianceScope=GDPR;ISO27001;SOC2`, `ChangeRef=CHG0012345`. Apply them to all resources (the *Resource* column shows *13 selected* by default).

5. `Review + create`: wait for *Validation passed*, check the summary and estimated cost, then `Create`. Deployment takes 3–8 minutes.

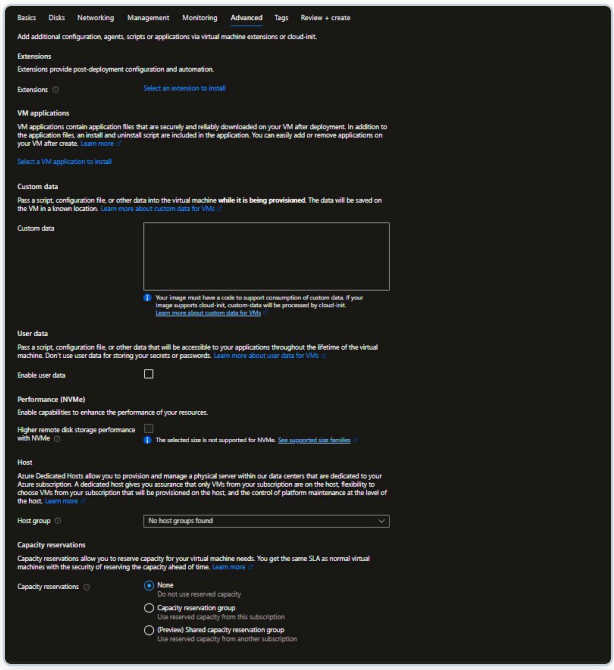


Figure 12. Advanced tab: extensions, VM applications, custom data, user data, NVMe, host group and capacity reservations.

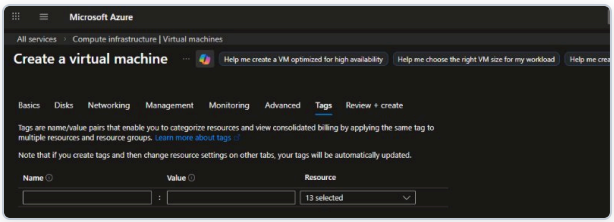


Figure 13. Tags tab: each tag applies to the selected resource types.

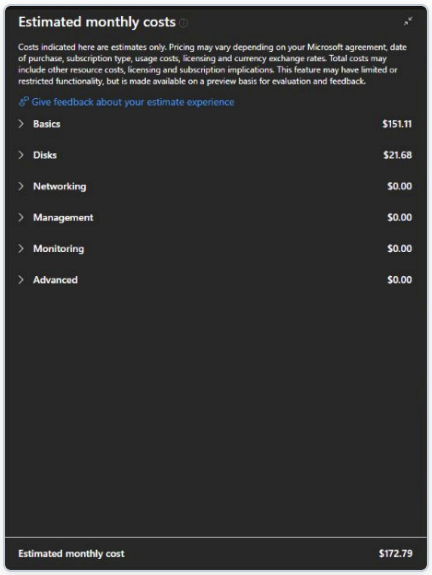


Figure 14. Estimated monthly cost panel for the reference build (compute $151.11 + Premium SSD $21.68 = $172.79, pay-as-you-go list price at the time).

CHAPTER 4

Method B · Az PowerShell Base Template

The template builds the same VM as Method A with every hardening choice explicit in code. It assumes the network, vault, workspace and data collection rule already exist (they are shared platform resources). It supports `-WhatIf`, refuses regions outside the allowed list, and writes a JSON evidence file.

NEW-HARDENEDAZVM.PS1 · BASE TEMPLATE POWERSHELL

```
<#
.SYNOPSIS  Deploy a hardened Windows Server VM: Trusted Launch, encryption at host, no public IP,
           managed identity, hotpatch, boot diagnostics, AMA + DCR, Azure Backup, tags, evidence.
.NOTES     Az.Accounts, Az.Compute, Az.Network, Az.Monitor, Az.RecoveryServices.  PowerShell 7+.
           Roles: VM Contributor (RG), subnet join (VNet), Backup Contributor (vault), Monitoring
Contributor.
#>
[CmdletBinding(SupportsShouldProcess)]
param(
  [Parameter(Mandatory)] [string] $SubscriptionId,
  [Parameter(Mandatory)] [string] $ResourceGroup,           # rg-web-prod-gwc
  [Parameter(Mandatory)] [string] $VmName,                  # vm-web-gwc-01
  [Parameter(Mandatory)] [string] $SubnetId,                # /subscriptions/.../subnets/snet-web
  [Parameter(Mandatory)] [pscredential] $AdminCredential,   # from Key Vault, never typed into a ticket
  [Parameter(Mandatory)] [string] $ChangeRef,
  [string]   $Location         = 'germanywestcentral',
  [string[]] $AllowedLocations = @('germanywestcentral'),
  [ValidateSet('1','2','3')] [string] $Zone = '1',
  [string]   $VmSize           = 'Standard_D2s_v5',
  [string]   $VaultName        = '',                        # Recovery Services vault (same region)
  [string]   $VaultResourceGroup = '',
  [string]   $BackupPolicyName = 'EnhancedPolicy-Daily',    # must be an Enhanced policy for Trusted
Launch
  [string]   $DcrId            = '',                        # data collection rule resource ID
  [hashtable] $Tags = @{ Environment='Production'; Owner='web-platform-team'; DataResidency='DE'
                         DataClassification='Confidential'; ComplianceScope='GDPR;ISO27001;SOC2' }
)
$ErrorActionPreference = 'Stop'
if ($Location -notin $AllowedLocations) { throw "Region '$Location' is not in the approved list." }
Connect-AzAccount -Subscription $SubscriptionId | Out-Null
$Tags.ChangeRef = $ChangeRef

# ---- Stage 0: pre-flight ------------------------------------------------------------------
$feat = Get-AzProviderFeature -FeatureName EncryptionAtHost -ProviderNamespace Microsoft.Compute
if ($feat.RegistrationState -ne 'Registered') { throw 'Register EncryptionAtHost first (see Disks tab).'
}
if (Get-AzVM -ResourceGroupName $ResourceGroup -Name $VmName -ErrorAction SilentlyContinue) { throw
"$VmName exists." }

# ---- Stage 1: NIC - private only, accelerated networking ----------------------------------
if ($PSCmdlet.ShouldProcess("$VmName-nic", 'Create NIC (no public IP)')) {
  $nic = New-AzNetworkInterface -Name "$VmName-nic" -ResourceGroupName $ResourceGroup -Location $Location
`
            -SubnetId $SubnetId -EnableAcceleratedNetworking -Tag $Tags
}

# ---- Stage 2: VM configuration ------------------------------------------------------------
$vm = New-AzVMConfig -VMName $VmName -VMSize $VmSize -Zone $Zone -IdentityType SystemAssigned `
```

```
        -EncryptionAtHost -Tags $Tags
$vm = Set-AzVMSecurityProfile -VM $vm -SecurityType TrustedLaunch
$vm = Set-AzVMUefi -VM $vm -EnableVtpm $true -EnableSecureBoot $true
$vm = Set-AzVMOperatingSystem -VM $vm -Windows -ComputerName $VmName.Substring(0,
[Math]::Min(15,$VmName.Length)) `
        -Credential $AdminCredential -ProvisionVMAgent -EnableAutoUpdate `
        -PatchMode AutomaticByPlatform -EnableHotpatching
$vm.OSProfile.WindowsConfiguration.PatchSettings.AssessmentMode = 'AutomaticByPlatform'   # periodic
assessment
$vm = Set-AzVMSourceImage -VM $vm -PublisherName MicrosoftWindowsServer -Offer WindowsServer `
        -Skus '2025-datacenter-azure-edition' -Version latest
$vm = Set-AzVMOSDisk -VM $vm -Name "$VmName-osdisk" -CreateOption FromImage -StorageAccountType
Premium_LRS `
        -DeleteOption Delete -Windows
$vm = Add-AzVMDataDisk -VM $vm -Name "$VmName-data01" -Lun 0 -CreateOption Empty -DiskSizeInGB 256 `
        -StorageAccountType Premium_LRS -Caching ReadOnly -DeleteOption Delete
$vm = Add-AzVMNetworkInterface -VM $vm -Id $nic.Id -DeleteOption Delete
$vm = Set-AzVMBootDiagnostic -VM $vm -Enable                    # managed storage account

# ---- Stage 3: deploy ------------------------------------------------------------------
if ($PSCmdlet.ShouldProcess($VmName, "New-AzVM in $Location zone $Zone")) {
  New-AzVM -ResourceGroupName $ResourceGroup -Location $Location -VM $vm | Out-Null
  $vmObj = Get-AzVM -ResourceGroupName $ResourceGroup -Name $VmName
}

# ---- Stage 4: Azure Monitor Agent + data collection rule ------------------------------
if ($DcrId -and $PSCmdlet.ShouldProcess($VmName, 'Install AMA + associate DCR')) {
  Set-AzVMExtension -ResourceGroupName $ResourceGroup -VMName $VmName -Location $Location `
    -Name AzureMonitorWindowsAgent -Publisher Microsoft.Azure.Monitor -ExtensionType
AzureMonitorWindowsAgent `
    -TypeHandlerVersion 1.0 -EnableAutomaticUpgrade $true | Out-Null
  New-AzDataCollectionRuleAssociation -AssociationName "$VmName-dcr" -ResourceUri $vmObj.Id -
DataCollectionRuleId $DcrId | Out-Null
}

# ---- Stage 5: Azure Backup (Enhanced policy) ------------------------------------------
if ($VaultName -and $PSCmdlet.ShouldProcess($VmName, "Enable backup in $VaultName")) {
  $vault  = Get-AzRecoveryServicesVault -ResourceGroupName $VaultResourceGroup -Name $VaultName
  $policy = Get-AzRecoveryServicesBackupProtectionPolicy -Name $BackupPolicyName -VaultId $vault.ID
  Enable-AzRecoveryServicesBackupProtection -ResourceGroupName $ResourceGroup -Name $VmName `
    -Policy $policy -VaultId $vault.ID | Out-Null
}

# ---- Evidence -------------------------------------------------------------------------
$vmObj = Get-AzVM -ResourceGroupName $ResourceGroup -Name $VmName
[ordered]@{
  ChangeRef = $ChangeRef; Operator = (Get-AzContext).Account.Id; TimeUtc = (Get-Date).ToUniversalTime()
  VmId = $vmObj.Id; Location = $vmObj.Location; Zone = ($vmObj.Zones -join ','); Size =
$vmObj.HardwareProfile.VmSize
  SecurityType = $vmObj.SecurityProfile.SecurityType; EncryptionAtHost =
$vmObj.SecurityProfile.EncryptionAtHost
  SecureBoot = $vmObj.SecurityProfile.UefiSettings.SecureBootEnabled; vTPM =
$vmObj.SecurityProfile.UefiSettings.VTpmEnabled
  PublicIp = [bool]((Get-AzNetworkInterface -ResourceId $nic.Id).IpConfigurations.PublicIpAddress)
  PrivateIp = (Get-AzNetworkInterface -ResourceId $nic.Id).IpConfigurations[0].PrivateIpAddress
  Identity = $vmObj.Identity.Type; Tags = $vmObj.Tags
} | ConvertTo-Json -Depth 4 | Out-File ".\$ChangeRef-$VmName-evidence.json"
Write-Host "$VmName deployed. Evidence: .\$ChangeRef-$VmName-evidence.json" -ForegroundColor Green
```

EXAMPLE · RUNNING THE TEMPLATE

INVOCATION POWERSHELL

```powershell
$cred = [pscredential]::new('azlocaladmin',
          (Get-AzKeyVaultSecret -VaultName kv-platform-gwc -Name vm-web-admin).SecretValue)
.\New-HardenedAzVm.ps1 -SubscriptionId '<sub-guid>' -ResourceGroup rg-web-prod-gwc -VmName vm-web-
gwc-01 `
  -SubnetId '<snet-web resource ID>' -AdminCredential $cred -ChangeRef CHG0012345 -Zone 1 `
  -VaultName rsv-prod-gwc -VaultResourceGroup rg-mgmt-prod-gwc -DcrId '<dcr resource ID>' -WhatIf
```

Run with `-WhatIf` first, then without. Repeat with `-VmName vm-web-gwc-02 -Zone 2` and `-03 -Zone 3`.

KEY CONCEPT · WHY THE EVIDENCE FILE READS BACK FROM AZURE

The evidence is collected from `Get-AzVM` *after* deployment rather than echoed from the parameters. That proves what Azure actually built (for example that encryption at host is on), which is what an auditor needs; parameters only prove what you asked for.

CHAPTER 5

Methods C and D · Azure CLI, Bicep and Policy Guardrails

5.1 Method C · Azure CLI

NEW-HARDENED-VM.SH BASH

```
RG=rg-web-prod-gwc; VM=vm-web-gwc-01; LOC=germanywestcentral; CHG=CHG0012345
SUBNET_ID=$(az network vnet subnet show -g rg-net-prod-gwc --vnet-name vnet-prod-gwc -n snet-web --query
id -o tsv)
ADMIN_PW=$(az keyvault secret show --vault-name kv-platform-gwc -n vm-web-admin --query value -o tsv)

az vm create -g $RG -n $VM -l $LOC --zone 1 --size Standard_D2s_v5 \
  --image MicrosoftWindowsServer:WindowsServer:2025-datacenter-azure-edition:latest \
  --security-type TrustedLaunch --enable-secure-boot true --enable-vtpm true \
  --encryption-at-host true --storage-sku Premium_LRS --os-disk-delete-option Delete \
  --data-disk-sizes-gb 256 --data-disk-delete-option Delete \
  --subnet $SUBNET_ID --public-ip-address "" --nsg "" --accelerated-networking true --nic-delete-option
Delete \
  --assign-identity '[system]' --admin-username azlocaladmin --admin-password "$ADMIN_PW" \
  --patch-mode AutomaticByPlatform --enable-hotpatching true \
  --tags Environment=Production Owner=web-platform-team DataResidency=DE ChangeRef=$CHG

az vm boot-diagnostics enable -g $RG -n $VM                  # managed storage
az vm extension set -g $RG --vm-name $VM -n AzureMonitorWindowsAgent \
  --publisher Microsoft.Azure.Monitor --enable-auto-upgrade true
az backup protection enable-for-vm -g rg-mgmt-prod-gwc --vault-name rsv-prod-gwc \
  --vm $(az vm show -g $RG -n $VM --query id -o tsv) --policy-name EnhancedPolicy-Daily
```

Passing a password on the command line can expose it in shell history; in pipelines read it from Key Vault at run time as shown, and clear the variable afterwards.

5.2 Method D · Bicep template

Bicep declares the end state; Azure Resource Manager creates or updates resources to match, and `what-if` previews the change. The template below shows the security-relevant properties; parameters for networking and credentials are supplied at deployment.

HARDENED-VM.BICEP TEXT

```
param location string = 'germanywestcentral'
param vmName string = 'vm-web-gwc-01'
param zone string = '1'
param subnetId string
@secure()
param adminPassword string
param tags object = { Environment: 'Production', Owner: 'web-platform-team', DataResidency: 'DE' }

resource nic 'Microsoft.Network/networkInterfaces@2024-01-01' = {
  name: '${vmName}-nic'
  location: location
  tags: tags
```

```
  properties: {
    enableAcceleratedNetworking: true
    ipConfigurations: [ { name: 'ipconfig1', properties: { subnet: { id: subnetId },
privateIPAllocationMethod: 'Dynamic' } } ]
  }
}
resource vm 'Microsoft.Compute/virtualMachines@2024-07-01' = {
  name: vmName
  location: location
  zones: [ zone ]
  tags: tags
  identity: { type: 'SystemAssigned' }
  properties: {
    hardwareProfile: { vmSize: 'Standard_D2s_v5' }
    securityProfile: {
      securityType: 'TrustedLaunch'
      uefiSettings: { secureBootEnabled: true, vTpmEnabled: true }
      encryptionAtHost: true
    }
    osProfile: {
      computerName: vmName
      adminUsername: 'azlocaladmin'
      adminPassword: adminPassword
      windowsConfiguration: {
        provisionVMAgent: true
        patchSettings: { patchMode: 'AutomaticByPlatform', enableHotpatching: true, assessmentMode:
'AutomaticByPlatform' }
      }
    }
    storageProfile: {
      imageReference: { publisher: 'MicrosoftWindowsServer', offer: 'WindowsServer', sku: '2025-
datacenter-azure-edition', version: 'latest' }
      osDisk: { createOption: 'FromImage', deleteOption: 'Delete', managedDisk: { storageAccountType:
'Premium_LRS' } }
    }
    networkProfile: { networkInterfaces: [ { id: nic.id, properties: { deleteOption: 'Delete' } } ] }
    diagnosticsProfile: { bootDiagnostics: { enabled: true } }
  }
}
output vmId string = vm.id
```

DEPLOY BASH

```
az deployment group what-if  -g rg-web-prod-gwc -f hardened-vm.bicep -p subnetId=$SUBNET_ID
adminPassword=$ADMIN_PW
az deployment group create   -g rg-web-prod-gwc -f hardened-vm.bicep -p subnetId=$SUBNET_ID
adminPassword=$ADMIN_PW
```

Add the AMA extension, DCR association and backup as further resources (`Microsoft.Compute/virtualMachines/extensions`, `Microsoft.Insights/dataCollectionRuleAssociations`, `Microsoft.RecoveryServices/vaults/backupFabrics/protectionContainers/protectedItems`) or let Azure Policy deploy them.

5.3 Guardrails with Azure Policy

Methods A–D rely on the builder doing the right thing; Azure Policy makes it mandatory by evaluating every create or update request before Azure Resource Manager accepts it. Assign these at the workload's management group or subscription:

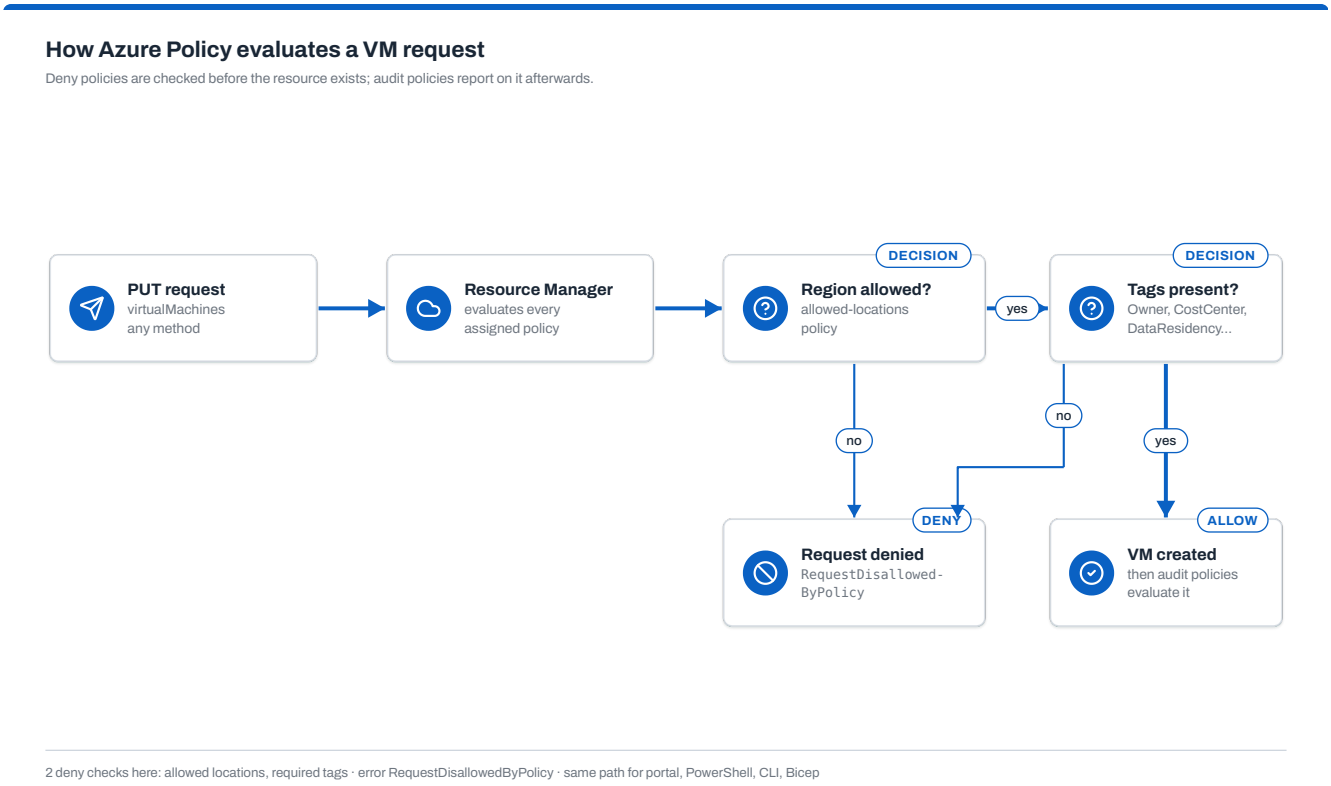


Figure 15. A deny policy stops a bad VM before it exists, which is far cheaper than finding it in an audit report afterwards.

Built-in policy (display name)	Effect	Purpose
Allowed locations	Deny	Only the approved residency regions (definition `e56962a6-4747-49cd-b67b-bf8b01975c4c`).
Require a tag on resources	Deny	One assignment per mandatory tag (Owner, DataClassification…).
Virtual machines and virtual machine scale sets should have encryption at host enabled	Audit / Deny	Catches VMs built without encryption at host.
Management ports should be closed on your virtual machines	Audit	Flags NSGs that expose RDP/SSH. Add DeployIfNotExists policies to install AMA automatically.

ASSIGN REGION + TAG GUARDRAILS POWERSHELL

```
$scope = '/subscriptions/<sub-guid>'
$loc = Get-AzPolicyDefinition -Id '/providers/Microsoft.Authorization/policyDefinitions/e56962a6-4747-49cd-b67b-bf8b01975c4c'
New-AzPolicyAssignment -Name allowed-locations -Scope $scope -PolicyDefinition $loc `
  -PolicyParameterObject @{ listOfAllowedLocations = @('germanywestcentral') }
$tag = Get-AzPolicyDefinition -Builtin | Where-Object { ($_.DisplayName, $_.Properties.DisplayName) -contains 'Require a tag on resources' }
foreach ($t in 'Owner','DataClassification','DataResidency') { New-AzPolicyAssignment -Name "require-tag-$t" -Scope $scope -PolicyDefinition $tag -PolicyParameterObject @{ tagName = $t } }
```

CHAPTER 6

Verification, Cost, Rollback and Troubleshooting

6.1 Verification checklist

Azure side

- ☐ Status *Running*; region, zone, size as planned
- ☐ Security type Trusted Launch; Secure Boot and vTPM on
- ☐ Encryption at host *Enabled* on the Disks blade
- ☐ No public IP on the NIC; NSG denies inbound from Internet
- ☐ Backup item *Protected*; first backup completed
- ☐ VM listed as healthy in Defender for Cloud
- ☐ All mandatory tags present; policy compliance *Compliant*

Inside the guest (via Bastion)

- ☐ Bastion RDP works; direct RDP from the internet fails
- ☐ `Confirm-SecureBootUEFI` returns *True*; `Get-Tpm` shows TPM present
- ☐ Data disk initialized and formatted
- ☐ `Get-MpComputerStatus`: real-time protection on
- ☐ Heartbeat in Log Analytics within 15 minutes
- ☐ Private IP recorded in the CMDB with owner and vault

LOG ANALYTICS · AGENT HEARTBEAT KQL

```
Heartbeat
| where Computer startswith "vm-web-gwc"
| summarize LastSeen = max(TimeGenerated) by Computer, Category, OSType
```

6.2 Cost considerations

The portal estimate for the reference build was **$172.79 per month per VM** (pay-as-you-go list price: compute $151.11 including the Windows licence, Premium SSD OS disk $21.68). Three zonal VMs are therefore roughly $520 per month before the shared and add-on services below. Prices vary by region and change over time; always use the Azure pricing calculator for the current figure.

Cost item	Note and saving lever
Compute	Largest item. Reserved instances or an Azure savings plan (1 or 3 years) and Azure Hybrid Benefit for existing Windows Server licences reduce it substantially.
Disks	Billed by provisioned size, running or not. Data disks add their own tier price.

Azure Bastion	Hourly charge per Bastion host, shared by every VM in the VNet (and peered VNets).
Azure Backup	Per-instance fee plus backup storage; Enhanced policy snapshots add snapshot storage.
Defender for Servers P2	Per server per hour; includes a daily Log Analytics data allowance.
Log Analytics	Per GB ingested and retained; tune the data collection rule.
Load balancer / App Gateway	Standard Load Balancer rules and data processed; Application Gateway WAF per hour plus capacity units.

6.3 Rollback

Situation	Action
Validation failed	Nothing created. Fix the reported setting and retry.
Deployment partially failed	Delete the VM; with *Delete with VM* options set, the disks and NIC go too. Sweep: `Get-AzResource -TagName ChangeRef -TagValue CHG0012345`.
VM built but must be removed	Stop protection in the vault (retain or delete backup data per policy) *before* deleting the VM, then delete the VM and remove it from the load-balancer pool and CMDB.
Wrong region	VMs cannot be moved between regions in place. Redeploy in the right region (or use Azure Resource Mover), then delete the original and any in-region backups per data-handling rules.

6.4 Troubleshooting

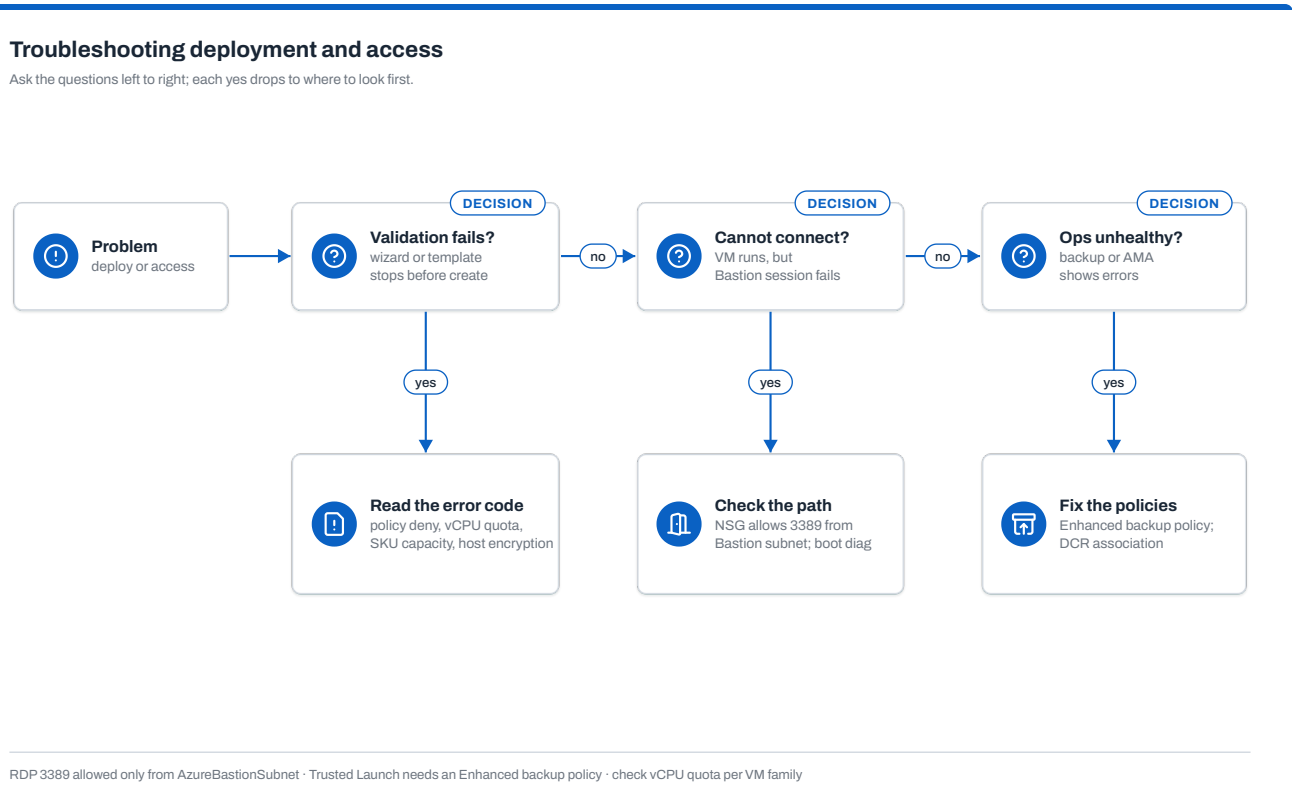


Figure 16. Validation errors name their cause in the error code, so read the code before changing anything.

Symptom	Likely cause and fix
`RequestDisallowedByPolicy`	Region, tag or encryption policy denied the request. The error names the assignment; correct the value rather than requesting an exemption.
"Encryption at host is not registered"	Register the `EncryptionAtHost` feature on the subscription, then re-register the `Microsoft.Compute` provider.
`SkuNotAvailable` / `ZonalAllocationFailed`	Size not offered or out of capacity in that zone. Try another zone or size; check `Get-AzComputeResourceSku`.
Trusted Launch option greyed out	Gen1 image or unsupported size. Pick a Gen2 image and a supported family.
Bastion connection fails	Subnet NSG must allow 3389 from the `AzureBastionSubnet` range; user needs Reader on VM, NIC and Bastion.
Enable backup fails for the VM	Trusted Launch VMs need an **Enhanced** backup policy; the vault must be in the same region.
No data in Log Analytics	AMA installed but no data collection rule association, or the managed identity is missing.

CHAPTER 7

Summary, Glossary and Review

7.1 Summary

- Choose an approved region and spread VMs across availability zones; keep backups, logs and replicas in the same residency boundary, and enforce it with Allowed-locations policy.
- Harden every wizard tab: Trusted Launch, encryption at host, Premium SSD, no public IP, subnet NSG, Bastion, managed identity, Entra login, Enhanced backup, hotpatch, boot diagnostics, AMA and mandatory tags.
- Script it (PowerShell, CLI or Bicep) for repeatability and read evidence back from Azure after deployment.
- Grant VM Contributor on the workload resource group and subnet-join on the VNet, eligible through PIM.

7.2 Glossary

Trusted Launch	VM security type with Secure Boot, vTPM and boot integrity monitoring.
Encryption at host	Host-level encryption of temp disks and disk caches.
SSE / CMK	Server-side encryption of managed disks; customer-managed key held in Key Vault.
NSG	Network security group: stateful allow/deny rules for a subnet or NIC.
Managed identity	Entra ID identity for an Azure resource, with no stored secret.
DCR	Data collection rule telling the Azure Monitor Agent what to collect and where to send it.

Check your understanding

1. Region choice is set correctly, yet data could still leave the geography. Name two ways and the controls that stop them.
2. What does encryption at host protect that server-side encryption alone does not?
3. Why should the NIC NSG usually be *None* when the subnet already has an NSG?
4. Which two roles, at which scopes, let an engineer build the VM without being able to change the VNet?
5. Why does a Trusted Launch VM fail to enable backup with the default policy, and how is it fixed?